

Informe CWE.

La CWE no es solo un catálogo de debilidades: desde 2025 se ha convertido, de facto, en una máquina de fabricar indicadores cuantitativos sobre la fragilidad de nuestro software y hardware, con una metodología bastante más refinada de lo que solemos admitir en reuniones de comité. La cuestión interesante, para España, es cómo convertir esos números en política pública, métricas nacionales y obligaciones regulatorias sin morir de powerpoints.¹²³⁴

1. Qué ha cambiado en CWE desde 2025 (y por qué importa para indicadores)

Desde 2025, el “CWE Top 25 Most Dangerous Software Weaknesses” se calcula con un dataset bastante serio: 39.080 CVE publicados entre junio de 2024 y junio de 2025, mapeados a CWE como causa raíz. Esto permite derivar métricas de prevalencia e impacto que ya no son solo opinión ilustrada de expertos, sino estadística aplicada a vulnerabilidades reales en el ecosistema global.⁵⁶⁷

El cambio metodológico más relevante: por primera vez en 2025, MITRE deja de “normalizar” los CWE a la vista 1003 (View-1003) y utiliza los mapeos tal y como los proporcionan las fuentes (CNAs, etc.), lo que da una imagen más fiel (aunque más ruidosa) de cómo se usan las categorías CWE en el mundo real. Esto es oro para cualquier marco nacional que quiera usar CWE como taxonomía oficial de debilidades, porque reduce el desajuste entre lo que dice el estándar y lo que las organizaciones realmente reportan.⁸⁹

En paralelo, la CWE amplía su foco a hardware con la lista “2025 Most Important Hardware Weaknesses (MIHW)”, que identifica debilidades críticas específicas de hardware (p.ej. problemas en interfaces de depuración, fallos de aislamiento entre dominios, etc.), con la intención explícita de guiar requisitos de diseño y verificación. Esta bifurcación software/hardware habilita dos familias de indicadores nacionales distintos, alineados pero no mezclados, algo clave para sectores españoles con mucha electrónica propia (defensa, transporte, industria 4.0).¹⁰¹¹¹²

1 https://cwe.mitre.org/top25/archive/2025/2025_methodology.html

2 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

3 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

4 https://cwe.mitre.org/top25/archive/2025/2025_key_insights.html

5 https://cwe.mitre.org/top25/archive/2025/2025_methodology.html

6 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

7 https://cwe.mitre.org/top25/archive/2025/2025_methodology.html

8 https://cwe.mitre.org/top25/archive/2025/2025_methodology.html

9 <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

2. La métrica “estrella”: el Analysis Score y sus derivadas

MITRE basa las listas Top 25 y el Top 10 de KEV (Known Exploited Vulnerabilities) en un “Analysis Score” que combina prevalencia y severidad de cada CWE. La fórmula exacta es menos importante que la idea: cada CWE obtiene una puntuación derivada de cuántas CVE mapeadas lo mencionan y qué severidad media (CVSS) arrastran esas vulnerabilidades.¹³¹⁴

En el Top 25 de 2025, la métrica de “CVE con mapeo a Top 25” asciende al 67% del dataset, un aumento de 14 puntos porcentuales respecto al año anterior, lo que sugiere que un pequeño conjunto de debilidades cubre la gran mayoría de vulnerabilidades reales. Esto habilita indicadores del tipo “porcentaje de vulnerabilidades nacionales atribuibles al Top 25” o “porcentaje de CVE críticos nacionales asociados a las 10 debilidades más explotadas”, muy útiles para concentrar políticas de mitigación.¹⁵¹⁶

El Top 10 KEV (centrado en vulnerabilidades efectivamente explotadas según el catálogo KEV) reutiliza la misma lógica de Analysis Score, pero sobre un subconjunto de CVE mucho más reducido (182 registros en el corte 2024–2025), lo que lo hace extremadamente sensible a cambios, pero muy informativo para priorización operativa. A nivel de indicadores nacionales, esto se traduce en métricas como “proporción de sistemas críticos nacionales expuestos a CWE presentes en el KEV Top 10” o “tiempo medio de corrección de debilidades KEV-mapeadas”.¹⁷¹⁸

3. Tipos de indicadores CWE que tienen sentido a nivel país

Aunque MITRE no publica un “manual de indicadores nacionales”, sí ofrece todos los elementos para construirlos: vistas de investigación (como CWE-1000), listas prioritarias (Top 25, MIHW, KEV) y estructuras formales para mapear vulnerabilidades a debilidades. A partir de ahí, la cocina nacional es cosa de cada país.¹⁹²⁰²¹

10 https://cwe.mitre.org/top25/archive/2025/2025_key_insights.html

11 <https://www.cve.org/Media/News/item/blog/2026/01/06/CVE-Records-Basis-2025-CWE-Top-25>

12 https://cwe.mitre.org/top25/archive/2025/2025_methodology.html

13 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

14 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

15 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

16 https://cwe.mitre.org/top25/archive/2025/2025_methodology.html

17 <https://www.cve.org/Media/News/item/blog/2026/01/06/CVE-Records-Basis-2025-CWE-Top-25>

18 [https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA Threat Landscape 2025_v1.2.pdf](https://www.enisa.europa.eu/sites/default/files/2026-01/ENISA%20Threat%20Landscape%202025_v1.2.pdf)

19 <https://cwe.mitre.org/data/definitions/1432.html>

En un marco territorial como España, los indicadores derivados de CWE pueden articularse (de forma razonablemente sobria) en cuatro bloques:

1. Indicadores de prevalencia de debilidades

Porcentaje de vulnerabilidades reportadas en el país mapeadas a cada CWE “top”.

Distribución por sector (administración pública, sanidad, energía, etc.) de los CWE predominantes.

Evolución anual de determinadas familias (p.ej. inyección, errores de memoria, autenticación).

Técnicamente, basta con que el CSIRT nacional (INCIBE-CERT, CCN-CERT, etc.) integre el mapeo CWE en su repositorio de incidentes y vulnerabilidades.³⁴

2. Indicadores de criticidad y riesgo

Media y distribución de CVSS por CWE en activos nacionales.³

Porcentaje de vulnerabilidades activamente explotadas (KEV) por CWE en infraestructuras críticas.⁸⁴

Peso de las debilidades de diseño versus implementación (aprovechando las categorías de CWE).⁹

3. Indicadores de desempeño (performance)

Tiempo medio de detección y remediación por CWE en organismos públicos y operadores esenciales.⁴³

Cobertura de controles preventivos frente a determinadas debilidades (por ejemplo, porcentaje de aplicaciones críticas sometidas a análisis estático capaz de detectar los CWE más frecuentes).¹⁰¹

Reducción interanual de la prevalencia de un subconjunto priorizado de CWE (objetivos de “vulnerabilidad reduction”).¹³

4. Indicadores de capacidad y madurez

Número de profesionales formados/certificados en análisis de debilidades CWE prioritarias, alineado con las estrategias de capacitación en ciberseguridad.¹¹¹²

Integración de CWE en marcos de desarrollo seguro, pliegos de contratación y esquemas de evaluación de conformidad (ENS, esquemas CCN, etc.).¹²³

²⁰ <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>

²¹ <https://www.cve.org/Media/News/item/blog/2026/01/06/CVE-Records-Basis-2025-CWE-Top-25>

- Porcentaje de vulnerabilidades reportadas en el país mapeadas a cada CWE “top”.
- Distribución por sector (administración pública, sanidad, energía, etc.) de los CWE predominantes.
- Evolución anual de determinadas familias (p.ej. inyección, errores de memoria, autenticación). Técnicamente, basta con que el CSIRT nacional (INCIBE-CERT, CCN-CERT, etc.) integre el mapeo CWE en su repositorio de incidentes y vulnerabilidades.³⁴
- Media y distribución de CVSS por CWE en activos nacionales.³
- Porcentaje de vulnerabilidades activamente explotadas (KEV) por CWE en infraestructuras críticas.⁸⁴
- Peso de las debilidades de diseño versus implementación (aprovechando las categorías de CWE).⁹
- Tiempo medio de detección y remediación por CWE en organismos públicos y operadores esenciales.⁴³
- Cobertura de controles preventivos frente a determinadas debilidades (por ejemplo, porcentaje de aplicaciones críticas sometidas a análisis estático capaz de detectar los CWE más frecuentes).¹⁰¹
- Reducción interanual de la prevalencia de un subconjunto priorizado de CWE (objetivos de “vulnerabilidad reduction”).¹³
- Número de profesionales formados/certificados en análisis de debilidades CWE prioritarias, alineado con las estrategias de capacitación en ciberseguridad.¹¹¹²
- Integración de CWE en marcos de desarrollo seguro, pliegos de contratación y esquemas de evaluación de conformidad (ENS, esquemas CCN, etc.).¹²³

Un ejemplo concreto de combinación podría ser: “En el sector sanitario español, el 80% de las vulnerabilidades reportadas en 2027 se concentra en diez CWE, de los cuales tres son debilidades de autenticación y control de acceso; el tiempo medio de remediación de esos tres CWE se ha reducido un 30% desde 2025”. Esta frase, si algún día existe, valdrá más que docenas de eslóganes estratégicos.

4. Enlace con estrategias europeas y españolas

Ni ENISA ni la Estrategia Nacional de Ciberseguridad española bajan explícitamente al nivel de “usar CWE como métrica obligatoria”, pero sí se apoyan en CVE, CVSS y taxonomías de vulnerabilidades que reconocen CWE como clasificación de referencia. En el Threat Landscape 2025, ENISA menciona CWE como marco estándar para clasificar vulnerabilidades y articular análisis por tipos (por ejemplo, inyección, desbordamientos, etc.), en conjunción con CVSS.²²²³

La estrategia nacional española, por su parte, insiste en la necesidad de proteger infraestructuras críticas, reforzar capacidades y promover el uso seguro de las TIC, pero deja a los marcos técnicos (ENS, guías CCN, etc.) la definición de taxonomías y métricas concretas. En paralelo, iniciativas como la estrategia de capacidades y competencias en ciberseguridad para España, enmarcadas en proyectos europeos de hubs de ciberseguridad, subrayan la necesidad de formar talento en marcos técnicos reconocidos internacionalmente, donde CWE aparece como uno de los lenguajes comunes para debilidades de software.²⁴²⁵

²² <https://www.cve.org/Media/News/item/blog/2026/01/06/CVE-Records-Basis-2025-CWE-Top-25>

²³ <https://cwe.mitre.org/data/definitions/1432.html>

En la práctica, si España decide usar CWE como eje de indicadores nacionales, tendrá a su favor la compatibilidad con:

- Los informes de ENISA, que ya asumen CWE como taxonomía estándar de debilidades.³⁴
- El ecosistema de CVE/CVSS, ampliamente usado en operaciones de ciberseguridad europeas.⁵³
- El corpus de investigación académica y de ingeniería segura que trabaja con CWE como referencia común.¹³⁹

Es decir: se puede pasar del discurso etéreo sobre “resiliencia digital” a cuadros de mando articulados sobre categorías CWE sin necesidad de inventar una taxonomía patria que nadie use fuera de nuestras fronteras.

5. Comparativa internacional: qué están haciendo otros (y qué podríamos copiar sin pudor)

Aunque los detalles operativos suelen ser discretos, se observa una tendencia clara en países y grandes organizaciones: usar CWE como lenguaje pivote para análisis de riesgo, métricas de programa de seguridad y requisitos de compra pública.²⁶²⁷

A nivel global, el uso del CWE Top 25 se ha consolidado como referencia para:

- Priorizar controles de seguridad en marcos de desarrollo seguro (por ejemplo, exigir que herramientas SAST/DAST detecten, al menos, las debilidades del Top 25).¹¹⁰
- Definir métricas de “reducción de vulnerabilidades” que miden desplomes en la prevalencia de ciertas CWE a lo largo del tiempo.¹³
- Guiar programas de formación de desarrolladores y arquitectos, centrando el currículo en las debilidades que realmente están detrás de la mayoría de CVE.¹⁰¹

En el plano europeo, ENISA anima a coleccionar datos de vulnerabilidades y amenazas siguiendo taxonomías comunes, entre ellas CWE, para poder consolidar análisis sectoriales comparables entre países. Esto abre la puerta a indicadores armonizados del estilo “tasa de CWE de inyección por millón de líneas de código en sistemas públicos críticos”, comparando no solo España con sí misma, sino España con otros Estados miembros que adopten métricas similares.²⁸²⁹

Para España, copiar sin rubor significaría:

²⁴ https://cwe.mitre.org/topHW/archive/2025/2025_CWE_MIHW.pdf

²⁵ https://cwe.mitre.org/top25/archive/2025/2025_kev_methodology.html

²⁶ https://cwe.mitre.org/top25/archive/2025/2025_kev_methodology.html

²⁷ <https://cwe.mitre.org/data/definitions/1000.html>

²⁸ <https://www.sans.org/top25-software-errors>

²⁹ <https://cyberhubs.eu/wp-content/uploads/2025/02/FINAL-2.3-SPAIN-CybersecuritySkillsStrategies.pdf>

- Incluir explícitamente CWE en auditorías técnicas y esquemas de certificación de productos y servicios TIC usados por la Administración, de manera similar a cómo algunos gobiernos exigen trazabilidad a CVE y CVSS.³⁴
- Requerir que los informes de vulnerabilidades a CSIRTs nacionales incluyan mapeo CWE, permitiendo construir series temporales comparables con el Top 25 mundial.⁵¹
- Conectar estos datos con los objetivos de la Estrategia Nacional de Ciberseguridad, de forma que “incrementar la resiliencia” deje de ser un desiderátum y pase a expresarse en variaciones porcentuales de debilidades concretas.¹²³

En síntesis: el mundo va hacia un uso cada vez más cuantitativo de CWE; España puede sumarse con ventaja porque ya está alineada con el marco europeo y carece de obstáculos conceptuales para adoptar estas métricas.

6. Propuesta de marco de indicadores CWE para España (versión “apliquemos algo de ciencia”)

Un consorcio mínimamente despierto de CISOs, académicos y reguladores españoles podría articular un marco de indicadores CWE en tres niveles, manteniendo la ironía a raya y el rigor estadístico al alza:

Nivel 1 – Visión país

- Porcentaje de vulnerabilidades reportadas en España (por CSIRTs nacionales y sectoriales) mapeadas a CWE del Top 25 global de cada año.⁵¹
- Distribución de CWE por sector esencial, alineado con la taxonomía de NIS2 y la Estrategia Nacional.¹²⁴
- Peso de debilidades de diseño versus implementación en sistemas críticos.⁶⁹

Nivel 2 – Visión sectorial

- Para cada sector estratégico (energía, salud, administración pública, transporte, etc.), identificación de las diez CWE más prevalentes y su evolución trienal.⁴³
- Tiempo medio de remediación por CWE crítico y porcentaje de activos todavía expuestos después de X días.⁸³
- Proporción de debilidades que coinciden con las listas KEV y MIHW (es decir, efectivamente explotadas o críticas en hardware).⁷⁶⁸

Nivel 3 – Visión organización

- Métricas de “densidad de debilidades CWE” por aplicación o sistema (por ejemplo, CWE por mil líneas de código o por “unidad funcional”).¹⁰¹
- Cobertura de controles de prevención y detección para las CWE top (p.ej. políticas de memoria segura, protecciones contra inyección, autenticación multifactor).¹³
- Porcentaje de proyectos que incluyen análisis de arquitectura explícito frente a debilidades de diseño identificadas en CWE.⁶⁹

Todo ello condicionado a una infraestructura mínima de datos: repositorios nacionales de vulnerabilidades con campos CWE, normalización de taxonomías y un cierto amor por los CSV. Pero, si se consigue, se podría evaluar la madurez de la ciberseguridad nacional con indicadores que tienen correspondencia directa en el corpus internacional de debilidades.

7. Pregunta incómoda (por si queremos ponernos serios)

La cuestión crucial para construir una batería de indicadores CWE a nivel nacional es el grado de integración que ya existe entre los CSIRTs españoles, las guías técnicas nacionales y las taxonomías internacionales (CWE/CVE/CVSS).³⁰³¹

1415

³⁰ https://cwe.mitre.org/top25/archive/2025/2025_kev_methodology.html

³¹ <https://dig.watch/resource/spains-national-cybersecurity-strategy>